TP 2 – SIMULATION D'ANALYSE DE VULNÉRABILITÉS (EXERCICE 3)

Module BC01 · Audit des infrastructures et conformité · ESATIC

Auteurs : DIABY Aboubacar Sidik, TEHI Stella Et OSSOHOU Tresor

Livrable : trois vulnérabilités documentées, méthode et outils de détection, mesures correctives.

1. MÉTHODE ET OUTILS DE DÉTECTION

Cible : srv-linux (10.10.20.15), Ubuntu 22.04.5 LTS, sous-réseau 10.10.20.0/24. Machine d'audit : Kali Linux (10.10.20.10). Toutes les commandes ont été exécutées dans le périmètre du laboratoire (loi n° 2013-451).

Étape	Outil / commande	Résultat
1. Découverte des hôtes	Nmap : nmap -sn 10.10.20.0/24 -oA decouverte	4 hôtes actifs (R1, SW1, Kali, srv-linux)
2. Services	Nmap : nmap -sS -sV -O -p- 10.10.20.15 -oA srv_complet ; -sU --top-ports 50	22/tcp OpenSSH 8.9p1 ; 80/tcp Apache 2.4.52 ; aucun port UDP ouvert
3. Détection par bannières	Nmap : nmap -sV --script vuln 10.10.20.15 -oA srv_vuln (moteur vulners)	CVE listées par correspondance de versions
4. Scan non authentifié	OpenVAS 25.04, config « Full and fast »	51 résultats bruts, 3 retenus (QoD ≥ 70), sévérité max 2.6 (Low)
5. Scan authentifié	OpenVAS, identifiants SSH (compte auditeur)	232 résultats bruts, 5 retenus, sévérité max 5.5 (Medium)
6. Validation	apt changelog, debsecan, catalogue CISA KEV	Faux positifs écartés, vrai positif confirmé

Comparaison des scans OpenVAS. Le scan authentifié (connexion SSH réussie) voit les versions réellement installées et l'état du noyau : il est le seul à remonter les alertes VMScape (CVSS 5.5) et TSA (CVSS 3.8). Les trois constats communs (MAC SSH faibles, horodatages TCP et ICMP) sont de faible risque. Aucun résultat critique ou élevé n'est retenu à QoD ≥ 70.

Démarche d'interprétation. Conformément au chapitre 3 (§5.2), chaque résultat brut a été validé par une seconde source (changelog du paquet installé, debsecan, catalogue KEV), puis contextualisé (exposition du service, mesures existantes) et corrélé entre Nmap, OpenVAS et le système.

Limites et précautions.

- Un seul actif a été scanné par OpenVAS (srv-linux) sur les 4 hôtes découverts ; R1 et SW1 relèvent du TP 1.
- Les rapports OpenVAS sont filtrés à QoD ≥ 70 : les détections moins fiables (12 critiques ou élevées en non authentifié, 79 en authentifié) ne sont pas détaillées et ont été traitées par vérification des correctifs.

- La détection d'OS de Nmap est approximative (Linux 4.x/5.x) ; le système réel (Ubuntu 22.04.5, noyau 5.15.0-119) est confirmé par SSH. Côté UDP, 30 ports restent « open|filtered » et aucun n'est ouvert.
- Le compte auditeur dispose de droits sudo : à retirer ou restreindre après l'audit pour qu'il soit réellement en lecture seule.
- Preuves conservées (sorties -oA, rapports XML, empreintes SHA-256) ; scans réalisés uniquement sur le laboratoire, sous autorisation.

2. LES TROIS VULNÉRABILITÉS DOCUMENTÉES

2.1 CVE-2024-6387 (regreSSHion) – OpenSSH

Description	Condition de course dans sshd pouvant permettre une exécution de code à distance avant authentification.
CVE / CVSS	CVE-2024-6387 · CVSS 8.1 (élevé)
CISA KEV	Oui, ajoutée le 25 février 2026 (exploitation active). Sans effet ici : le correctif est déjà appliqué.
Détection	Nmap (vulners) et OpenVAS : bannière OpenSSH 8.9p1, dans la plage annoncée vulnérable (8.5p1 à 9.7p1).
Validation	apt changelog openssh-server : correctif CVE-2024-6387.patch (26/06/2024) présent dans la version installée 1:8.9p1-3ubuntu0.17.
Faux positif ?	OUI. Ubuntu rétroporte le correctif sans changer le numéro de version affiché.
Risque réel	Nul.
Mesure corrective	Aucune action. Consigner comme faux positif vérifié pour éviter un traitement inutile.

2.2 CVE-2022-31813 – Apache httpd (mod_proxy)

Description	mod_proxy ne transmet pas correctement les en-têtes X-Forwarded-*, ce qui peut permettre de contourner des restrictions basées sur l'adresse IP source.
CVE / CVSS	CVE-2022-31813 · CVSS 9.8 (critique)
CISA KEV	Non.
Détection	Nmap (vulners) et OpenVAS : bannière Apache 2.4.52 (corrigé en amont en 2.4.54).
Validation	apt changelog apache2 : correctif CVE-2022-31813.patch (14/06/2022) présent dans la version installée 2.4.52-1ubuntu4.23.
Faux positif ?	OUI. Même mécanisme de rétroportage (backport) Ubuntu.
Risque réel	Nul.
Mesure corrective	Aucune action. Consigner comme faux positif pour ne pas fausser le taux de conformité.

2.3 CVE-2025-32462 – sudo (option --host)

Description	L'option -h / --host de sudo peut servir à exécuter une commande, et non seulement à lister les privilèges. Si sudoers restreint des règles à un hôte précis (différent de ALL), un utilisateur local peut obtenir les privilèges prévus pour une autre machine.
CVE / CVSS	CVE-2025-32462 · CVSS 8.8, élevé (CVSS 3.1, NVD, AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H). Ubuntu évalue un vecteur plus faible : le score varie selon la source.
CISA KEV	Non.
Détection	debsecan sur srv-linux : sudo listé parmi les paquets porteurs de CVE non corrigées (sudo 1.9.9 aussi inventorié par le scan authentifié).
Validation	Version installée 1.9.9-1ubuntu2.4 ; correctif présent à partir de 1.9.9-1ubuntu2.5 (25/06/2025). La version installée est donc antérieure au correctif.
Faux positif ?	NON. Vrai positif confirmé.
Risque réel	Modéré. Non exploitable depuis le réseau : exige un accès local préalable et n'est exploitable que si /etc/sudoers contient des règles restreintes à un hôte autre que ALL (à vérifier).
Mesure corrective	Mettre à jour sudo vers 1.9.9-1ubuntu2.5 ou ultérieure (sudo apt update && sudo apt install --only-upgrade sudo) et vérifier /etc/sudoers.

3. SYNTHÈSE DES TROIS VULNÉRABILITÉS

Vulnérabilité	CVSS	KEV	Nature	Risque réel	Action
CVE-2024-6387 (OpenSSH)	8.1	Oui	Faux positif (backport)	Nul	Aucune
CVE-2022-31813 (Apache)	9.8	Non	Faux positif (backport)	Nul	Aucune
CVE-2025-32462 (sudo)	8.8	Non	Vrai positif	Modéré (accès local)	Mettre à jour sudo

Priorisation (chapitre 3, §3.8 : quatre facteurs).

Vulnérabilité	Sévérité (CVSS)	Exploitabilité (KEV)	Exposition	Priorité / qualification RGSSI B.10.13
CVE-2024-6387 (OpenSSH)	8.1, élevé	Oui, mais corrigée	Port 22 joignable sur le réseau	Aucune · C (conforme, correctif installé)
CVE-2022-31813 (Apache)	9.8, critique	Non	Port 80 joignable sur le réseau	Aucune · C (conforme, correctif installé)
CVE-2025-32462 (sudo)	8.8, élevé	Non	Locale uniquement	Priorité 1 · PC (paquet non à jour)

Criticité de l'actif : srv-linux est un serveur de laboratoire ; elle serait à pondérer en production. L'EPSS n'a pas été consulté. La qualification C / PC est proposée par les auteurs selon la grille du chapitre 2.

Faux négatif à noter. CVE-2025-32462 (vrai positif) n'apparaît pas dans les résultats OpenVAS retenus, même en scan authentifié ; seul debsecan l'a révélée. À l'inverse, les scores élevés de Nmap étaient des faux positifs. Aucun outil ne suffit seul : il faut croiser les sources.

Un score CVSS élevé ou une simple correspondance de bannière ne suffit pas à conclure : seule la vérification des correctifs réellement installés (scan authentifié, apt changelog, debsecan) distingue un vrai d'un faux positif.

4. MESURES CORRECTIVES, PAR ORDRE DE PRIORITÉ

Priorité	Action	Indicateur de suivi
1 (haute)	Mettre à jour sudo et contrôler /etc/sudoers	Version sudo ≥ 1.9.9-1ubuntu2.5 ; re-scan authentifié
2 (moyenne)	Qualifier VMScape (5.5) et TSA (3.8), puis mettre à jour noyau et microcode	Constats clos ou override justifié dans OpenVAS
3 (basse)	Durcir SSH (MAC umac-64), horodatages TCP et ICMP	Constats absents du re-scan
4 (suivi)	Consigner les 2 faux positifs dans le registre de suivi	Taux de conformité non faussé

Détail des mesures :

- Mettre à jour le paquet sudo (CVE-2025-32462) et contrôler le fichier /etc/sudoers.
- Mettre à jour le noyau et le microcode (intel-microcode ou amd64-microcode), puis redémarrer ; qualifier d'abord l'exposition réelle à VMScape et TSA (uname -r, lscpu), et créer un override OpenVAS si le processeur n'est pas concerné.
- Durcir SSH et le réseau : retirer les MAC umac-64 de la directive MACs de sshd_config, ajouter net.ipv4.tcp_timestamps = 0 (sysctl -p), filtrer les messages ICMP timestamp au pare-feu.
- Documenter les constats OpenSSH et Apache comme faux positifs vérifiés dans le registre de suivi.